

คู่มือเตรียมสอบ: ความมั่นคงปลอดภัยไซเบอร์ (Cyber Security Lecture Notes)

สรุปเนื้อหาเจาะลึก 15 หัวข้อหลัก สำหรับทบทวนเพื่อการสอบระดับมหาวิทยาลัยอย่างมั่นใจ

สารบัญเนื้อหา (Table of Contents)

1. การตรวจสอบเว็บไซต์ก่อนใช้งานและการประเมินผลกระทบ
2. ลักษณะและประเภทของภัยคุกคามทางไซเบอร์ (Cyber Threats)
3. การจัดแบ่งระดับของภัยคุกคาม (Threat Levels)
4. หน้าที่และกระบวนการทำงานที่สำคัญของหน่วยงานด้าน Cyber Security
5. โครงสร้างหน่วยงานดูแลความปลอดภัยและรับแจ้งเหตุในประเทศไทย
6. สถานการณ์และภาพรวมภัยคุกคามทางไซเบอร์ในประเทศไทย
7. เป้าหมายและแรงจูงใจในการโจมตีระบบ (Cyber Attack Objectives)
8. การจำแนกประเภทของแฮกเกอร์ (Types of Hackers)
9. ลำดับขั้นของการโจมตีอย่างเป็นระบบ (Cyber Kill Chain)
10. ปัญหาความมั่นคงไร้พรมแดนและอนุสัญญาบูดาเปสต์ (Budapest Convention)
11. กรอบการดำเนินงานระดับสากล (Cyber Security Framework) และสถานการณ์โลก
12. เจาะลึกกระบวนการทำงานและตัวอย่างภัยคุกคามยอดนิยม
13. แนวทางการป้องกันตนเองและการใช้เทคโนโลยีดิจิทัลอย่างปลอดภัย
14. กฎหมายดิจิทัลและความมั่นคงปลอดภัยไซเบอร์ที่ควรรู้
15. สรุปภาพรวมและข้อแนะนำประยุกต์สำหรับการทำข้อสอบ

1. การตรวจสอบเว็บไซต์ก่อนใช้งานและการประเมินผลกระทบ

การรักษาความปลอดภัยในระดับบุคคลเริ่มต้นจากการมี "ความตระหนักรู้" (Awareness) ในการใช้งานอินเทอร์เน็ต โดยด่านแรกสุดคือการประเมินความปลอดภัยของเว็บไซต์ปลายทางก่อนการป้อนข้อมูลสำคัญใดๆ

กลไกการตรวจสอบความปลอดภัยของเว็บไซต์

- **การตรวจสอบโปรโตคอลการสื่อสาร (HTTPS):** เว็บไซต์ที่ปลอดภัยในปัจจุบันต้องใช้โปรโตคอล **HTTPS (Hypertext Protocol Secure)** ซึ่งเป็นการรวมโปรโตคอล HTTP เข้ากับ SSL/TLS เพื่อทำการเข้ารหัสข้อมูล (Encryption) ระหว่างเว็บเบราว์เซอร์ของผู้ใช้กับเซิร์ฟเวอร์ ช่วยป้องกันการดักจับข้อมูลกลางทาง (Man-in-the-Middle Attack)

- **สัญลักษณ์รูปแม่กุญแจ:** แสดงถึงการมีใบรับรองดิจิทัล (Digital Certificate) ที่ออกโดยหน่วยงานที่น่าเชื่อถือ (Certificate Authority - CA) อย่างไรก็ตาม ในปัจจุบันมีจาชพสามารถขอใบรับรองฟรีได้เช่นกัน ดังนั้นรูปแม่กุญแจจึงบอกได้เพียงว่าข้อมูลได้รับการเข้ารหัส แต่ไม่ได้การันตีว่าเจ้าของเว็บไม่ใช่โจร
- **การสะกดชื่อโดเมน (Domain Verification):** แฮกเกอร์มักใช้วิธีสร้างโดเมนเลียนแบบที่เรียกว่า **Typosquatting** หรือการสะกดผิดเนียนๆ เช่น `g00gle.com` (ใช้เลขศูนย์), `facebook.com` (เพิ่มตัวโอ) หรือการทำ **Homograph Attack** โดยใช้ตัวอักษรในภาษาอื่นที่หน้าตาเหมือนภาษาอังกฤษเพื่อพรางตาผู้ใช้

หลักการประเมินอุบัติการณ์ภัยคุกคาม (Incident Assessment)

เมื่อเกิดความผิดปกติในระบบ องค์กรจำเป็นต้องประเมินผลกระทบใน 4 ด้านหลัก เพื่อคัดกรองความรุนแรงของสถานการณ์:

1. **ผลกระทบต่อระบบและอุปกรณ์:** ความเสียหายที่เกิดขึ้นกับโครงสร้างทางกายภาพ เซิร์ฟเวอร์ หรือฮาร์ดแวร์หลัก
2. **ผลกระทบต่อข้อมูล:** การพิจารณาว่าข้อมูลสูญหาย ถูกเปลี่ยนแปลง หรือถูกดึงออกไปภายนอก (Data Leakage) มากน้อยเพียงใด
3. **แนวโน้มการลุกลาม:** มัลแวร์หรือการโจมตีนั้นสามารถกระจายตัวหรือขยายวงกว้างไปยังระบบเครือข่ายอื่นได้เร็วเพียงใด
4. **ผลกระทบต่อผู้ใช้บริการ:** ปริมาณผู้ใช้งานหรือประชาชนที่ไม่สามารถเข้าถึงระบบหรือบริการได้ตามปกติ

ตัวอย่างสถานการณ์จริง

พนักงานในบริษัทได้รับลิงก์ทางอีเมลระบุว่า `https://amazon-login.com/security` เพื่อให้รับเข้าใช้อัปเดตข้อมูลบัญชีด่วน หากมองผ่านๆ อาจคิดว่าเป็นเว็บจริงของ Amazon แต่เมื่อตรวจสอบอย่างละเอียดพบว่าใช้เลข 0 แทนตัวอักษร o นี่คือนีเว็บฟิชซิงปลอมที่สร้างขึ้นมาเพื่อดักจับชื่อผู้ใช้และรหัสผ่านโดยเฉพาะ

แนวข้อสอบที่อาจออก

โจทย์: หากพบเว็บไซต์ที่มีเครื่องหมายแม่กุญแจและขึ้น HTTPS เรียบร้อย แต่ชื่อ URL สะกดว่า `www.example.com` ข้อใดสรุปได้ถูกต้องที่สุด?

แนวคำตอบ: เว็บไซต์นั้นมีการเข้ารหัสข้อมูลสื่อสารจริง แต่เป็นเว็บไซต์ที่น่าสงสัยและอาจเป็นเว็บปลอม (Typosquatting) เนื่องจากการมี HTTPS ไม่ได้การันตีความซื่อสัตย์ของเจ้าของเว็บไซต์

สรุปง่าย

ตรวจสอบเว็บให้ดู 3 จุด: **HTTPS + แม่กุญแจ + ตัวสะกดโดเมนห้ามเพี้ยน** และเมื่อเกิดเหตุต้องประเมินผลกระทบ 4 ด้านเสมอ คือ **ระบบ ข้อมูล การลุกลาม และผู้ใช้งาน** เพื่อวางแผนรับมืออย่างถูกต้อง

2. ลักษณะและประเภทของภัยคุกคามทางไซเบอร์ (Cyber Threats)

ภัยคุกคามไซเบอร์ คือการกระทำหรือเหตุการณ์ใดๆ ที่มีความจงใจจะก่อให้เกิดความเสียหาย ขโมยข้อมูล แทรกแซง หรือทำลายระบบคอมพิวเตอร์และเครือข่ายสารสนเทศ

การแบ่งประเภทมัลแวร์และรูปแบบการโจมตีเชิงลึก

- **Malware (Malicious Software):** เป็นคำกว้างๆ ที่ใช้เรียกซอฟต์แวร์ประสงค์ร้ายทุกประเภทที่ออกแบบมาเพื่อทำงานแฝงในระบบโดยที่ผู้ใช้ไม่รู้ยินยอม
- **Virus:** โปรแกรมคอมพิวเตอร์ที่สามารถสำเนาตัวเองได้ แต่มีข้อจำกัดคือ ต้องเกาะติดไปกับไฟล์หรือโปรแกรมอื่น และต้องการการกระทำของมนุษย์ (เช่น การเปิดโปรแกรม) ในการสั่งให้ทำงานและแพร่กระจาย
- **Worm (หนอนคอมพิวเตอร์):** เป็นมัลแวร์ประเภทอันตรายสูงที่สามารถ สำเนาตัวเองและแพร่กระจายไปยังเครื่องอื่นๆ ผ่านระบบเครือข่ายได้อย่างอิสระ โดยไม่ต้องพึ่งพาไฟล์โฮสต์และไม่ต้องอาศัยการกดสั่งรันของมนุษย์
- **Trojan (ม้าโทรจัน):** โปรแกรมที่แฝงมาในรูปแบบที่ดูเหมือนเป็นซอฟต์แวร์ที่มีประโยชน์หรือปลอดภัย แต่เมื่อผู้ใช้ติดตั้งและรันโปรแกรมแล้ว มันจะแอบเปิดช่องทางให้แฮกเกอร์เข้ามาควบคุมเครื่องจากระยะไกล
- **Ransomware (มัลแวร์เรียกค่าไถ่):** โจมตีโดยการเข้ารหัสลับไฟล์เอกสารและข้อมูลสำคัญทั้งหมดบนเครื่องเป้าหมาย ทำให้เหยื่อไม่สามารถเปิดไฟล์ได้ จากนั้นจะแสดงหน้าต่างเรียกร้องให้จ่ายเงินค่าไถ่ (มักเป็น Cryptocurrency) แลกกับกุญแจถอดรหัส
- **Spyware:** ซอฟต์แวร์ที่แอบฝังตัวเพื่อบันทึกพฤติกรรมการใช้งาน เช่น ดักจับการกดแป้นพิมพ์ (Keylogger) หรือขโมยประวัติการเข้าเว็บเพื่อส่งกลับไปให้แฮกเกอร์
- **Phishing:** รูปแบบการโจมตีโดยใช้เทคนิควิศวกรรมสังคม ส่งข้อความหรืออีเมลหลอกลวงที่หน้าตาเหมือนมาจากองค์กรที่น่าเชื่อถือ เพื่อดึงใจให้เหยื่อส่งมอบข้อมูลส่วนตัว
- **DDoS (Distributed Denial of Service):** การโจมตีโดยใช้เครื่องคอมพิวเตอร์ที่ติดมัลแวร์จำนวนมหาศาล (เรียกว่า Botnet) ระบุส่งคำสั่งขอใช้งานระบบไปยังเซิร์ฟเวอร์เป้าหมายพร้อมๆ กัน จนทรัพยากรของเซิร์ฟเวอร์เต็มและระบบล่มในที่สุด

ตัวอย่างสถานการณ์จริง

พนักงานฝ่ายจัดซื้อเปิดไฟล์ใบแจ้งหนี้ปลอมที่แนบมากับอีเมล มัลแวร์ประเภท Ransomware เริ่มทำงานทันทีด้วยการใส่เข้ารหัสไฟล์งานทั้งหมดในเครื่องและไฟล์แชร์ในเครือข่ายบริษัท พร้อมทั้งข้อความเรียกเงินค่าไถ่จำนวน 100,000 บาทเพื่อแลกกับการได้ข้อมูลคืน

แนวข้อสอบที่อาจออก

โจทย์: ข้อใดคือความแตกต่างที่สำคัญที่สุดระหว่าง Virus และ Worm ในระบบคอมพิวเตอร์?

แนวคำตอบ: Virus จำเป็นต้องอาศัยไฟล์โฮสต์ในการเกาะติดและต้องใช้มนุษย์ในการสั่งรันเพื่อแพร่กระจาย ในขณะที่ Worm สามารถสำเนาตัวเองและกระจายตัวผ่านเครือข่ายได้ด้วยตัวเองโดยไม่ต้องพึ่งพาไฟล์โฮสต์หรือมนุษย์

สรุปง่าย

มัลแวร์แต่ละตัวมีเอกลักษณ์: **Virus** ต้องพึ่งไฟล์/คน, **Worm** รังได้เองทั่วเน็ต, **Trojan** หลอกว่าดีแต่แฝงร้าย, **Ransomware** ล็อคไฟล์ขู่เงิน, **Spyware** แอบส่งดักข้อมูล, **Phishing** เน้นหลอกลวง และ **DDoS** เน้นรุมกล่อมให้ระบบล่ม

3. การจัดแบ่งระดับของภัยคุกคาม (Threat Levels)

การแบ่งระดับความรุนแรงของภัยคุกคามเป็นกลไกสำคัญในการบริหารจัดการความเสี่ยง ช่วยให้ทีมรักษาความปลอดภัยไซเบอร์สามารถจัดลำดับความสำคัญและตอบสนองต่ออุบัติการณ์ (Incident Response) ได้อย่างทันทั่วถึงและสมเหตุสมผล

เกณฑ์การประเมินระดับความรุนแรง

ตามมาตรฐานทั่วไปรวมถึงแนวทางของ พ.ร.บ. การรักษาความมั่นคงปลอดภัยไซเบอร์ จะมีการแบ่งระดับออกเป็น 4 ระดับหลักตามขอบเขตความเสียหาย:

ระดับภัยคุกคาม	ลักษณะความเสียหายและขอบเขตผลกระทบ	ตัวอย่างเหตุการณ์จริง
ระดับต่ำ (Low)	กระทบต่ออุปกรณ์เดียวหรือผู้ใช้งานจำนวนน้อย ไม่ส่งผลกระทบต่อระบบหลัก ควบคุมได้ง่ายภายในเวลาสั้นๆ	คอมพิวเตอร์พนักงาน 1 เครื่อง ติดไวรัส ทิ้งไปจากแฟลชไดรฟ์
ระดับปานกลาง (Medium)	กระทบต่อระบบย่อยภายในองค์กร หรือข้อมูลภายในที่ไม่วิกฤตหลุดรั่ว มีระบบสำรองรองรับทำให้ธุรกิจยังเดินหน้าได้	ระบบอีเมลภายในล่มบางส่วน หรือเว็บไซต์ประชาสัมพันธ์ขององค์กรถูกเปลี่ยนหน้าโฮมเพจ (Defacement)
ระดับสูง (High)	ระบบหลักที่ให้บริการพังเสียหาย โดนเจาะฐานข้อมูลหลักทำให้ข้อมูลส่วนบุคคลหรือความลับลูกค้ารั่วไหลจำนวนมาก	เซิร์ฟเวอร์ฐานข้อมูลของบริษัทอีคอมเมิร์ซถูกแฮก และข้อมูลบัตรเครดิตลูกค้าหลุดไปขายบน Dark Web
ระดับวิกฤต (Critical)	ส่งผลกระทบอย่างรุนแรงต่อโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) ระดับประเทศ เสี่ยงต่อความสงบเรียบร้อย ชีวิต ทรัพย์สิน หรือความมั่นคงของรัฐ	ระบบควบคุมการจ่ายไฟฟ้าระดับภูมิภาคถูกแฮกเกอร์ฝังมัลแวร์สั่งปิดระบบ ส่งผลให้ไฟดับเป็นวงกว้าง

แนวข้อสอบที่อาจออก

โจทย์: หากโรงพยาบาลประจำจังหวัดแห่งหนึ่งถูกโจมตีด้วยมัลแวร์เรียกค่าไถ่จนแพทย์ไม่สามารถเข้าถึงข้อมูลประวัติการรักษาและแพทย์ของคนที่ใช้ในไอซียูได้ เหตุการณ์นี้ควรจัดอยู่ในภัยคุกคามระดับใด?

แนวคำตอบ: จัดอยู่ในระดับ **วิกฤต (Critical)** หรือระดับสูงมาก เนื่องจากสาธารณสุขเป็นโครงสร้างพื้นฐานสำคัญ (CII) และเหตุการณ์นี้ส่งผลกระทบโดยตรงต่อชีวิตและความปลอดภัยของมนุษย์

สรุปง่าย

ความรุนแรงแบ่งตามวงกว้างของผลกระทบ: ต่ำ = เครื่องเดียว, ปานกลาง = ระบบย่อย/นำรำคาญ, สูง = ข้อมูลรั่ว/ระบบหลักพัง, วิกฤต = โครงสร้างพื้นฐานประเทศพังกระทบชีวิตและทรัพย์สินประชาชน

4. หน้าที่และกระบวนการทำงานที่สำคัญของหน่วยงานด้าน Cyber Security

หน่วยงานหรือทีมงานด้านความมั่นคงปลอดภัยไซเบอร์ (เช่น SOC - Security Operations Center หรือ CERT) ทำหน้าที่เหมือนระบบภูมิคุ้มกันและกองกำลังพิทักษ์ทรัพย์สินดิจิทัลขององค์กร โดยดำเนินงานตามวงจรที่เป็นระบบ

กระบวนการทำงานหลักตามมาตรฐาน Incident Response

1. **การป้องกัน (Protect):** การวางมาตรการเชิงรุกเพื่อลดโอกาสการเกิดเหตุ เช่น การตั้งค่า Firewall, การอัปเดตระบบ ติดตั้งแพตช์ความปลอดภัย (Patching), การกำหนดสิทธิ์เข้าถึงข้อมูลขั้นต่ำ (Least Privilege) และการจัดอบรมสร้างจิตสำนึกให้พนักงาน
2. **การเฝ้าระวังและตรวจจับ (Detect):** การมอนิเตอร์กราฟฟิคและตรวจสอบล็อกไฟล์ (Log Analysis) ตลอด 24 ชั่วโมง โดยใช้ระบบ SIEM (Security Information and Event Management) เพื่อค้นหาสิ่งผิดปกติ เช่น มีการพยายามล็อกอินล้มเหลวติดต่อกันหมื่นครั้งใน 1 นาที
3. **การรับมือและควบคุมเหตุ (Respond & Contain):** เมื่อตรวจพบการโจมตี ทีมงานต้องเข้าควบคุมสถานการณ์ทันที เพื่อจำกัดพื้นที่ความเสียหาย (Containment) เช่น สั่งตัดสัญญาณเครือข่ายของเครื่องที่ติดมัลแวร์ไม่ให้แพร่กระจาย และเริ่มกำจัดต้นตอ (Eradication)
4. **การฟื้นฟูระบบ (Recover):** กระบวนการทำให้ระบบกลับมาเปิดใช้งานได้ตามปกติอย่างปลอดภัย โดยทำการตรวจสอบความเรียบร้อย นำข้อมูลจากระบบสำรอง (Backup) มาใช้ และอุดช่องโหว่เดิมเพื่อไม่ให้เกิดเหตุซ้ำ

ตัวอย่างสถานการณ์จริง

ระบบแจ้งเตือนพบว่า มีบัญชีของพนักงานล็อกอินเข้ามาจากพิกัดต่างประเทศทั้งที่พนักงานคนนั้นยังนั่งทำงานอยู่ในออฟฟิศ ทีม Cyber Security จึงดำเนินการบล็อกสิทธิ์เข้าใช้งานชั่วคราว (Contain) และบังคับเปลี่ยนรหัสผ่าน พร้อมตรวจสอบ Log ย้อนหลังทันที

สรุปง่าย

สี่เสาหลักของการรักษาความปลอดภัยไซเบอร์: **ป้องกัน (ทำให้ระบบให้แข็งแรง) -> ตรวจจับ (เฝ้าระวังหาจุดผิดปกติ) -> รับมือ (ตัดไฟแต่ต้นลมจำกัดวงความเสียหาย) -> ฟื้นฟู (กู้ระบบให้กลับมาทำงานปกติอย่างปลอดภัย)**

5. โครงสร้างหน่วยงานดูแลความปลอดภัยและรับแจ้งเหตุในประเทศไทย

เมื่อเกิดเหตุภัยคุกคามไซเบอร์ในประเทศไทย มีหน่วยงานภาครัฐเฉพาะทางที่จัดตั้งขึ้นตามกฎหมายเพื่อกำหนดที่ดูแล ประสานงาน และปราบปรามอาชญากรรมทางเทคโนโลยีแยกตามบทบาทหน้าที่อย่างชัดเจน

หน่วยงานสำคัญและบทบาทหน้าที่

- **สมช. (NCSA - สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ):** หน่วยงานระดับนโยบายของประเทศ มีหน้าที่กำกับดูแลภาพรวมการรักษาความมั่นคงปลอดภัยไซเบอร์ บังคับใช้ พ.ร.บ. ไซเบอร์ฯ และคอยดูแลหน่วยงานที่เป็นโครงสร้างพื้นฐานสำคัญ (CII)
- **ThaiCERT (ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์ประเทศไทย):** ปัจจุบันย้ายมาอยู่ภายใต้สมช. ทำหน้าที่เป็นศูนย์ประสานงานกลางในเชิงเทคนิค คอยรับแจ้งเหตุอุบัติการณ์ไซเบอร์จากทั้งภาครัฐและเอกชน ช่วยวิเคราะห์ภัยคุกคาม และออกคำแนะนำ (Advisory) แก่ประชาชน
- **บช.สอท. (CCIB - กองบัญชาการตำรวจสืบสวนสอบสวนอาชญากรรมทางเทคโนโลยี หรือ ตำรวจไซเบอร์):** เป็นหน่วยงานบังคับใช้กฎหมาย มีอำนาจหน้าที่สืบสวน สอบสวน รวบรวมพยานหลักฐาน เพื่อจับกุมผู้กระทำความผิดมาดำเนินคดีตามกฎหมายอาญาและ พ.ร.บ. คอมพิวเตอร์ฯ

- **ETDA (สำนักงานพัฒนาธุรกรรมทางอิเล็กทรอนิกส์):** ปัจจุบันเน้นบทบาทด้านการส่งเสริม มาตรฐาน มาตรฐานโครงสร้างพื้นฐานการทำธุรกรรมออนไลน์ พาณิชย์อิเล็กทรอนิกส์ (E-Commerce) กฎหมาย Digital ID และการดูแลความปลอดภัยในการแลกเปลี่ยนข้อมูลเชิงพาณิชย์

สถานการณ์ที่เกิดขึ้น	หน่วยงานหลักที่รับผิดชอบ	รูปแบบการช่วยเหลือ
ประชาชนถูกแก๊งคอลเซ็นเตอร์หลอกโอนเงิน	ตำรวจไซเบอร์ (บช.สอท.)	รับแจ้งความ ดำเนินคดีตามกฎหมาย แกะรอยบัญชีม้า
องค์กรโดนแฮกเกอร์ขโมยข้อมูล ต้องการคำแนะนำทางเทคนิค	ThaiCERT / สกมช.	ส่งทีมผู้เชี่ยวชาญร่วมวิเคราะห์หาสาเหตุและประสานงานรับมือ
ต้องการใบรับรองมาตรฐานการทำธุรกรรมทางอิเล็กทรอนิกส์	ETDA	กำหนดมาตรฐาน Guideline และให้การรับรองความปลอดภัยในการค้าออนไลน์

สรุปง่าย

โครงสร้างไซเบอร์ไทย: สกมช. คุณนโยบายประเทศ, ThaiCERT เป็นหมอกคอยตรวจและประสานงานเทคนิคแก้ไข, ตำรวจไซเบอร์ (บช.สอท.) เป็นผู้จับกุมผู้ร้าย และ ETDA คุมมาตรฐานการทำธุรกรรมออนไลน์

6. สถานการณ์และภาพรวมภัยคุกคามทางไซเบอร์ในประเทศไทย

สถานการณ์ภัยคุกคามในประเทศไทยมีเอกลักษณ์เฉพาะตัว โดยอาชญากรมักหันมาใช้วิธีโจมตีทางจิตวิทยาผสมผสานกับเทคโนโลยี (Social Engineering-led Attacks) พุ่งเป้าไปที่ผู้ใช้งานทั่วไปมากกว่าการเจาะระบบหลังบ้านโดยตรง

3 ภัยคุกคามยอดฮิตในสถิติปัจจุบัน

1. **แก๊งคอลเซ็นเตอร์ (Call Center Scams):** การใช้เทคโนโลยี VoIP ปลอมแปลงเบอร์โทรศัพท์ (IP Spoofing) แอบอ้างเป็นเจ้าหน้าที่รัฐ (เช่น ตำรวจ ศาล ดิเอสโอ หรือเจ้าหน้าที่โปรดยักษ์) โทรสร้างความตกใจ กลัว หรือหลงเชื่อ เพื่อบังคับให้โอนเงินไปยังบัญชีปลายทาง
2. **แอปพลีเคชันดักเงิน (Remote Access Trojan):** แฮกเกอร์ส่ง SMS หรือสร้างโฆษณาปลอมหลอกให้เหยื่อติดตั้งแอปพลิเคชันนอก Store (ไฟล์ .apk) โดยแอบอ้างเป็นหน่วยงานรัฐ เช่น กรมที่ดิน การไฟฟ้า หรือสรรพากร เมื่อติดตั้งแล้ว แอปจะหลอกให้เหยื่อเปิดสิทธิ์ **Accessibility Service** ซึ่งสิทธิ์นี้จะอนุญาตให้แอปอ่านค่านับหน้าจอ สั่งกดปุ่มเองได้ ทำให้แฮกเกอร์ควบคุมมือถือจากระยะไกลเพื่อโอนเงินออกและดักจับ OTP ได้อย่างสมบูรณ์
3. **บัญชีม้าและซิมม้า (Mule Accounts & SIMs):** ขบวนการจัดหาและรับซื้อบัญชีธนาคารหรือซิมการ์ดจากบุคคลทั่วไปเพื่อนำไปใช้เป็นเครื่องมือในการรับเงินที่ได้จากการหลอกลวง ข้อมูลสถิติชี้ว่าบัญชีม้าเป็นตัวการหลักที่ทำให้เกิดเงินไหลออกนอกประเทศได้อย่างรวดเร็วผ่านการโอนต่อเป็นทอดๆ

แนวข้อสอบที่อาจออก

โจทย์: ในทางเทคนิค เหตุใดแอปพลิเคชันดูดเงินในระบบปฏิบัติการ Android จึงสามารถโอนเงินออกจากแอปธนาคารของเหยื่อได้ ทั้งๆ ที่ผู้ใช้ไม่ได้กดยินยอมในแอปธนาคาร?

แนวคำตอบ: เพราะแอปดูดเงินหลอกให้ผู้ใช้เปิดสิทธิ์ "Accessibility Service" (บริการช่วยเหลือการเข้าถึง) ซึ่งทำให้แฮกเกอร์มองเห็นหน้าจอ ดักรหัสพิน ดักรหัส OTP และส่งคำสั่งจำลองการกดนิ้วเพื่อโอนเงินออกได้เสมือนใช้งานเครื่องอยู่จริง

สรุปง่าย

ภัยไซเบอร์ในไทยเน้น "**หลอกคน**" เป็นหลัก ผ่านแก๊งคอลเซ็นเตอร์สร้างความกลัว และหลอกติดตั้งแอปดูดเงินที่อาศัยช่องโหว่ของการเปิดสิทธิ์ Accessibility ใน Android โดยมีบัญชีม้าคอยรับเงินฟอกส่งต่อ

7. เป้าหมายและแรงจูงใจในการโจมตีระบบ (Cyber Attack Objectives)

การเข้าใจแรงจูงใจ (Motivations) เบื้องหลังการโจมตีช่วยให้ผู้เชี่ยวชาญด้านความปลอดภัยสามารถประเมินพฤติกรรมและคาดการณ์ทรัพย์สินข้อมูล (Digital Assets) ที่แฮกเกอร์ต้องการปกป้องหรือเข้าถึงได้ล่วงหน้า

4 แรงจูงใจหลักของ Cyber Attack

- **ผลประโยชน์ทางการเงิน (Financial Gain):** เป็นแรงจูงใจที่พบบ่อยที่สุดในปัจจุบัน แฮกเกอร์โจมตีเพื่อขโมยเงินโดยตรง ขโมยข้อมูลบัตรเครดิต หรือใช้มัลแวร์เรียกค่าไถ่เพื่อรีดไถเงินจากองค์กรธุรกิจ รวมถึงการขโมยพลังงานประมวลผลไปชุดเหรียญคริปโต (Cryptojacking)
- **การจารกรรมข้อมูล (Espionage):** พุ่งเป้าไปที่การขโมยทรัพย์สินทางปัญญา ความลับทางการค้า สูตรการผลิต แผนงานทางธุรกิจ หรือข้อมูลความมั่นคงระดับชาติ เพื่อสร้างความได้เปรียบในการแข่งขันทางธุรกิจหรือความขัดแย้งระหว่างประเทศ
- **การก่อวินาศกรรมและทำลายล้าง (Disruption/Sabotage):** มีวัตถุประสงค์เพื่อสร้างความเสียหายต่อชื่อเสียง โครงสร้างระบบ หรือทำให้ระบบหยุดทำงานจนไม่สามารถให้บริการได้ ซึ่งอาจเกิดจากความแค้นส่วนตัวของพนักงานภายในองค์กร (Insider Threat) หรือการแข่งขันที่สกปรก
- **การแสดงออกเชิงอุดมการณ์ (Ideological/Hacktivism):** การโจมตีที่ไม่ได้มุ่งหวังเงินทองหรือความลับ แต่ต้องการประกาศจุดยืนทางการเมือง ศาสนา หรือสังคม โดยการเจาะหน้าเว็บเพื่อประท้วงหรือแฉข้อมูลลับขององค์กรที่แฮกเกอร์เกลียดชัง

สรุปง่าย

แฮกเกอร์ลงมือเพื่อเป้าหมาย 4 อย่าง: **เงิน (เรียกค่าไถ่/ขโมยตรง)** -> **ลับ (สอดแนม/จารกรรมข้อมูลธุรกิจ)** -> **พัง (ก่อวินาศกรรมระบบด้วยความแค้น)** -> **อุดมการณ์ (เจาะเว็บประท้วงเรื่องการเมือง/สังคม)**

8. การจำแนกประเภทของแฮกเกอร์ (Types of Hackers)

คำว่า "แฮกเกอร์" (Hacker) ในทางวิทยาการคอมพิวเตอร์เป็นคำกลางๆ การระบุตัวตนและระดับความอันตรายจะตัดสินจาก "เจตนา" (Intent) และ "สิทธิ์การได้รับอนุญาตทางกฎหมาย"

การแบ่งกลุ่มแฮกเกอร์ตามสัญลักษณ์หมวด

- **White Hat Hacker (แฮกเกอร์หมวกขาว):** ผู้เชี่ยวชาญด้านความปลอดภัยที่มีจริยธรรม ทำหน้าที่ค้นหาช่องโหว่ของระบบโดยได้รับความยินยอมเป็นลายลักษณ์อักษรจากเจ้าของระบบ เพื่อป้องกันและอุดรอยรั่วก่อนที่คนร้ายจะเจอ เช่น พนักงานตำแหน่ง Penetration Tester (ผู้ทดสอบเจาะระบบ)
- **Black Hat Hacker (แฮกเกอร์หมวกดำ):** อาชญากรไซเบอร์ที่เจาะระบบโดยไม่มีสิทธิ์และผิดกฎหมาย มีเจตนาทุจริตเพื่อขโมยข้อมูล เรียกค่าไถ่ หรือทำลายระบบเพื่อประโยชน์ส่วนตัว บางครั้งเรียกว่า "แครกเกอร์" (Cracker)
- **Gray Hat Hacker (แฮกเกอร์หมวกเทา):** แฮกเกอร์สายลูกผสม ไม่มีเจตนาร้ายแต่ทำผิดกฎหมายด้วยการเจาะระบบโดยไม่ได้รับอนุญาตล่วงหน้า เมื่อพบช่องโหว่จะแจ้งไปยังเจ้าของระบบเพื่อขอเงินรางวัล (Bug Bounty) หรือนำไปเปิดเผยต่อสาธารณะเพื่อกระตุ้นให้แก้ไข
- **Script Kiddie:** แฮกเกอร์มือสมัครเล่นหรือเด็กหัดแฮกที่ไม่มีความรู้ลึกซึ้งเกี่ยวกับการเขียนโค้ดหรือโครงสร้างระบบ แต่อาศัยการดาวน์โหลดซอฟต์แวร์หรือสคริปต์สำเร็จรูปที่คนอื่นเขียนไว้มาทดลองยิงโจมตีระบบผู้อื่นเพื่อความสนุกหรือโอ้อวด
- **Hacktivist (แฮกเกอร์นักกิจกรรม):** การรวมคำระหว่าง Hacker + Activist เป็นกลุ่มแฮกเกอร์ที่ใช้ทักษะทางไซเบอร์โจมตีเป้าหมายเพื่อขับเคลื่อนอุดมการณ์ทางการเมือง ปล่อยข้อมูลลับของรัฐบาล หรือต่อต้านทุนนิยม (เช่น กลุ่ม Anonymous)
- **State-Sponsored Hacker (แฮกเกอร์ที่รัฐสนับสนุน):** ทีมแฮกเกอร์ระดับหัวกะทิที่มีรัฐบาลบางประเทศให้การสนับสนุนและจัดหาเครื่องมือระดับสูง มีเป้าหมายจารกรรมข้อมูลความมั่นคงหรือโจมตีระบบโครงสร้างพื้นฐานของประเทศคู่กรณี มักทำงานเป็นกลุ่มลับที่เรียกว่า **APT (Advanced Persistent Threat)**

แนวข้อสอบที่อาจออก

โจทย์: บุคคลที่ตรวจพบช่องโหว่ในเว็บไซต์ของธนาคาร แล้วทำการเจาะเข้าไปดึงข้อมูลเพื่อมาแจ้งเตือนให้ธนาคารทราบและเรียกร้องเงินรางวัล โดยไม่ได้นำข้อมูลไปเผยแพร่ที่อื่น จัดอยู่ในกลุ่มใด?

แนวคำตอบ: จัดอยู่ในกลุ่ม **Gray Hat Hacker (หมวกเทา)** เนื่องจากกระทำการเจาะระบบโดยไม่ได้รับสิทธิ์อนุญาตล่วงหน้า (ละเมิดกฎหมาย) แต่เจตนาปลายทางไม่ใช่การทำลายระบบหรือขายข้อมูลเชิงร้าย

สรุปง่าย

จำตามเจตนาและสิทธิ์: ขาว = ได้รับอนุญาต/ช่วยอุดช่องโหว่, ดำ = ขโมย/ทำลาย/ผิดกฎหมาย, เทา = ไม่ขออนุญาตแต่ไม่ทำร้าย, Script Kiddie = ใช้เครื่องมือชาวบ้านโซ้วเก๋า, Hacktivist = แฮกเพื่ออุดมการณ์การเมือง และ State-Sponsored = กองทัพไซเบอร์ของรัฐบาล

9. ลำดับขั้นของการโจมตีอย่างเป็นระบบ (Cyber Kill Chain)

Cyber Kill Chain เป็นกรอบแนวคิดที่พัฒนาโดยบริษัท Lockheed Martin เพื่อใช้วิเคราะห์และระบุลำดับขั้นตอนการโจมตีทางไซเบอร์ในรูปแบบ APT (Advanced Persistent Threat) ของแฮกเกอร์มืออาชีพ หัวใจของมันคือ หากองค์กรสามารถสกัดกั้นหรือตัดโซ่ตรวนนี้ในขั้นตอนใดขั้นตอนหนึ่งได้ การโจมตีทั้งหมดจะล้มเหลวทันที

7 ขั้นตอนของ Cyber Kill Chain

1. **Reconnaissance (การสืบค้นและรวบรวมข้อมูล):** ขั้นตอนการหาข้อมูลเกี่ยวกับเป้าหมาย เช่น หาอีเมลพนักงานผ่านโซเชียลมีเดีย สแกนพอร์ตเครือข่ายเพื่อหาซอฟต์แวร์เวอร์ชันเก่าที่มีช่องโหว่
2. **Weaponization (การสร้างอาวุธประสงค์ร้าย):** แฮกเกอร์นำข้อมูลช่องโหว่ที่พบมารวมเข้ากับเครื่องมือโจมตี (Payload) และประกอบเข้าด้วยกันเป็นไฟล์อันตราย เช่น ฝังแม่โครไวรัสไว้ในไฟล์เอกสาร PDF หรือ Excel
3. **Delivery (การส่งมอบอาวุธ):** การส่งไฟล์อันตรายนั้นไปยังเป้าหมายผ่านช่องทางต่างๆ เช่น ส่งอีเมล Phishing, การเอาแฟลชไดรฟ์ไปวางทิ้งไว้ หรือแฮกหน้าเว็บปกติให้ฝังลิงก์ดาวน์โหลดมัลแวร์
4. **Exploitation (การเจาะช่องโหว่):** เกิดขึ้นเมื่อเหยื่อหลงกลเปิดไฟล์หรือคลิกลิงก์ ทำให้อาวุธไซเบอร์เริ่มทำงานโดยอาศัยช่องโหว่ของระบบปฏิบัติการหรือแอปพลิเคชันที่ไม่ได้อัปเดตเพื่อแทรกตัว
5. **Installation (การติดตั้งมัลแวร์):** มัลแวร์ทำการฝังตัวเองลงในระบบปฏิบัติการของเหยื่อ สร้างช่องทางให้ทำงานได้ถาวร (Persistence) แม้จะมีการรีสตาร์ทเครื่องคอมพิวเตอร์ก็ตาม
6. **Command & Control (C2 - การควบคุมระยะไกล):** เครื่องของเหยื่อที่ติดเชื้อจะเปิดช่องทางสื่อสารเข้ารหัสส่งสัญญาณกลับไปยังเซิร์ฟเวอร์ควบคุมของแฮกเกอร์ (C2 Server) เพื่อรอรับคำสั่งการโจมตีขั้นต่อไป
7. **Actions on Objectives (การลงมือตามเป้าหมาย):** แฮกเกอร์สั่งการควบคุมเครื่องเหยื่อทำการกิจสุดท้ายสำเร็จ เช่น สั่งดึงฐานข้อมูลออกไป (Data Exfiltration) สั่งเข้ารหัสล็อกไฟล์เพื่อเรียกค่าไถ่ หรือใช้เป็นฐานกระจายการเจาะระบบไปยังเครื่องอื่นในองค์กร (Lateral Movement)

ตัวอย่างสถานการณ์จริงแบบร้อยเรียงใน Kill Chain

แฮกเกอร์หาชื่ออีเมลของฝ่ายบัญชีจากเว็บไซต์บริษัท (Recon) -> นำโปรแกรมโทรจันไปผูกกับไฟล์ตารางราคาสินค้า (Weaponize) -> ส่งอีเมลหาฝ่ายบัญชีอ้างว่าเป็นลูกค้ารายใหญ่ (Delivery) -> พนักงานกดเปิดไฟล์งาน (Exploit) -> มัลแวร์ฝังเข้า Registry หลังบ้าน (Install) -> เครื่องเปิดพอร์ตเชื่อมกลับไปหาแฮกเกอร์ (C2) -> แฮกเกอร์ไล่ดึงข้อมูลเงินเดือนและงบการเงินทั้งหมดของบริษัทออกไปขาย (Actions on Objectives)

สรุปง่าย

ลำดับโจมตี 7 ขั้น: สืบหาข้อมูล (Recon) -> ประกอบระเบิด (Weaponize) -> ส่งข้ามแดน (Delivery) -> บึ้มช่องโหว่ (Exploit) -> ฝังรากลึก (Install) -> ตั้งวิทยุรับคำสั่ง (C2) -> ปล้นเงิน/ข้อมูล (Actions)

10. ปัญหาความมั่นคงไร้พรมแดนและอนุสัญญาบูดาเปสต์ (Budapest Convention)

เนื่องจากอินเทอร์เน็ตสร้างโลกที่ไร้พรมแดน ปัญหาที่ใหญ่ที่สุดในการปราบปรามแฮกเกอร์คือ **"ขอบเขตอำนาจศาลและกฎหมาย" (Jurisdiction Problem)** เช่น แฮกเกอร์นั่งอยู่ประเทศรัสเซีย เข้าเซิร์ฟเวอร์ในสิงคโปร์ เพื่อเจาะระบบธนาคารในไทย เงินหล่นไปที่บัญชีม้าในกัมพูชา ทำให้กฎหมายของประเทศใดประเทศหนึ่งไม่สามารถจัดการได้เพียงพอ

อนุสัญญาบูดาเปสต์ (Budapest Convention on Cybercrime)คืออะไร?

เป็นสนธิสัญญาระหว่างประเทศฉบับแรกที่จัดทำขึ้นในปี ค.ศ. 2001 โดยสภายุโรป (Council of Europe) มีวัตถุประสงค์หลักเพื่อสร้างมาตรฐานและกรอบความร่วมมือระดับสากลในการจัดการกับอาชญากรรมทางคอมพิวเตอร์

3 เสาหลักของอนุสัญญาบูดาเปสต์

- **การประสานกฎหมายสารบัญญัติ (Harmonization of Laws):** บังคับให้ประเทศสมาชิกต้องเขียนกฎหมายภายในประเทศให้มีความสอดคล้องมาตรฐานกัน เช่น กำหนดให้การแฮกข้อมูล การทำอาชญากรรมออนไลน์ และความฉ้อโกงทางคอมพิวเตอร์เป็นความผิดทางอาญาเหมือนกันทุกประเทศ
- **การเพิ่มอำนาจทางกฎหมายวิธีพิจารณาความ (Procedural Powers):** การอนุญาตให้เจ้าหน้าที่สามารถตรวจยึดค้น และดักจับข้อมูลหลักฐานดิจิทัลได้อย่างมีประสิทธิภาพภายใต้การคุ้มครองสิทธิมนุษยชน
- **ความร่วมมือระหว่างประเทศที่รวดเร็ว (International Cooperation):** จัดตั้งเครือข่ายติดต่อประสานงานด่วนตลอด 24 ชั่วโมง (24/7 Network) เพื่อแลกเปลี่ยนข้อมูล พยานหลักฐานดิจิทัล หรือขอความร่วมมืออายัดข้อมูลข้ามประเทศได้ทันทีโดยไม่ต้องผ่านกระบวนการทางทูตที่ล่าช้า

แนวข้อสอบที่อาจออก

โจทย์: วัตถุประสงค์หลักและสำคัญที่สุดของอนุสัญญาบูดาเปสต์ (Budapest Convention) คืออะไร?

แนวคำตอบ: เพื่อสร้างกรอบความร่วมมือระหว่างประเทศในการปราบปรามอาชญากรรมไซเบอร์ ผ่านการประสานกฎหมายให้เป็นมาตรฐานสากลและเอื้อให้เกิดการแลกเปลี่ยนพยานหลักฐานดิจิทัลข้ามพรมแดนได้อย่างรวดเร็ว

สรุปง่าย

แฮกเกอร์โจมตีข้ามประเทศกฎหมายตามจับยาก จึงต้องมี **"อนุสัญญาบูดาเปสต์"** เพื่อให้ทุกประเทศ **ออกกฎหมาย ฐานความผิดเหมือนกัน และเปิดช่องทางด่วน 24/7 ช่วยส่งหลักฐานดิจิทัลข้ามแดนจับโจร**

11. กรอบการดำเนินงานระดับสากล (Cyber Security Framework) และสถานการณ์โลก

การบริหารจัดการไซเบอร์ในระดับองค์กรและระดับประเทศจำเป็นต้องมี **"กรอบการทำงาน" (Framework)** ที่เป็นระบบ เพื่อให้หลุดรอดสายตาและเป็นภาษาเดียวกันในการประเมินความเสี่ยง

NIST Cybersecurity Framework (NIST CSF)

เป็นกรอบงานที่ได้รับความนิยมสูงที่สุดในโลก พัฒนาโดยสถาบันมาตรฐานและเทคโนโลยีแห่งชาติสหรัฐอเมริกา ประกอบด้วยฟังก์ชันหลักในการบริหารจัดการอุบัติการณ์ไซเบอร์ 5 ฟังก์ชัน (ในเวอร์ชันคลาสสิกที่มักออกสอบ):

1. **Identify (ระบุ):** สำรวจและทำความเข้าใจบริบท ทรัพย์สินที่มีในองค์กร (ฮาร์ดแวร์, ซอฟต์แวร์, ข้อมูล) เพื่อประเมินความเสี่ยง
2. **Protect (ป้องกัน):** การวางมาตรการควบคุมเพื่อจำกัดหรือป้องกันความเสียหาย เช่น ลงทุนระบบ Firewall, เข้ารหัสข้อมูล, ทำนโยบายสิทธิ์
3. **Detect (ตรวจจับ):** จัดตั้งระบบและกิจกรรมที่สามารถค้นพบสิ่งแปลกปลอมหรือการบุกรุกได้อย่างรวดเร็ว เช่น การตั้งทีม SOC
4. **Respond (รับมือ):** การเตรียมการและดำเนินการเมื่อตรวจพบการบุกรุก เพื่อสกัดกั้นและจำกัดผลกระทบ
5. **Recover (ฟื้นฟู):** แผนการกู้คืนระบบและความสามารถในการดำเนินธุรกิจให้กลับมาเป็นปกติหลังเกิดวิกฤต

สถานการณ์ภาพรวมและการลงทุนระดับโลก

ในปัจจุบัน ภัยคุกคามทางไซเบอร์ได้ยกระดับจากอาชญากรรมทั่วไปกลายเป็น **สงครามไซเบอร์ (Cyber Warfare)** ประเทศมหาอำนาจ เช่น สหรัฐอเมริกา (มีหน่วยงาน CISA), สหภาพยุโรป (ENISA) และกลุ่มประเทศพัฒนาแล้ว ต่างบรรจุโดเมนไซเบอร์เป็น "สมรภูมิรบที่ 5" ถัดจาก บก เรือ อากาศ และอวกาศ ทั่วโลกมีการทุ่มงบประมาณเพิ่มขึ้นมหาศาลในทุกปีเพื่อป้องกันโครงสร้างระบบสาธารณูปโภค พลังงาน และระบบการเงินจากการโจมตีของต่างชาติ

สรุปง่าย

กรอบงานระดับโลก NIST CSF ท่องจำให้ขึ้นใจ 5 ขั้นตอน: **Identify (รู้ว่ามีอะไรเสี่ยง)** -> **Protect (ป้องกันให้แน่นหนา)** -> **Detect (มองหาจุดผิดปกติ)** -> **Respond (รับมือสกัดกั้น)** -> **Recover (กู้คืนระบบให้กลับมาทำมาหากินได้ต่อ)**

12. เจาะลึกกระบวนการทำงานและตัวอย่างภัยคุกคามยอดนิยม

เพื่อการทำความเข้าใจแบบกรณีศึกษา (Case Study) จำเป็นต้องแยกแยะกลไกการทำงานเชิงโครงสร้างและความแตกต่างของภัยคุกคามแต่ละแบบออกจากกันอย่างแม่นยำ

เปรียบเทียบกลไกเชิงลึกของ 4 ภัยคุกคามสำคัญ

ประเภทภัยคุกคาม	กลไกและช่องโหว่หลักที่ใช้โจมตี	ตัวอย่างสถานการณ์จริงในระบบ
Social Engineering (วิศวกรรมสังคม)	ศาสตร์ภาพรวมที่ใช้ จิตวิทยาความกลัว ความโลภ ความเห็นอกเห็นใจ หรือความไว้วางใจ ของมนุษย์เป็นช่องโหว่หลักในการหลอกลวง แทนที่จะเจาะระบบคอมพิวเตอร์ตรงๆ	คนร้ายโทรศัพท์มาหลอกพนักงานไอทีมือใหม่ว่าตนเป็นซีอีโอ สัมผัสผ่านเข้าระบบด่วน ขอรหัสผ่านชั่วคราว
Phishing (ฟิชชิ่ง)	รูปแบบย่อยของวิศวกรรมสังคมที่ส่งผ่าน สื่ออิเล็กทรอนิกส์ (อีเมล, SMS, เว็บไซต์ปลอม) เพื่อหลอกลวงให้เหยื่อป้อนข้อมูลสำคัญ หรือกดลิงก์ดาวน์โหลดมัลแวร์	ได้รับอีเมลแจ้งเตือนจากธนาคารปลอมว่า "บัญชีถูกระงับชั่วคราว กรุณาคลิกลิงก์เพื่อยืนยันตัวตน"
Ransomware (มัลแวร์เรียกค่าไถ่)	ซอฟต์แวร์ประสงค์ร้ายที่ใช้ อัลกอริทึมการเข้ารหัสลับแบบอสมมาตร (Asymmetric Encryption) ข้อมูลบนเครื่องเหยื่อ แฮกเกอร์จะถือคีย์ถอดรหัสไว้คนเดียว	โรงพยาบาลโดนล็อกระบบข้อมูล ประวัติคนไข้ทั้งหมด แยกเกอร์ส่งคำขู่หน้าจอให้โอน 5 Bitcoin แลกคีย์ถอดรหัส
Data Breach (การรั่วไหลของข้อมูล)	ผลลัพธ์สุดท้ายของการโจมตีที่ทำให้ ข้อมูลความลับ ข้อมูลส่วนบุคคล หลุดรอดออกสู่สภาพแวดล้อมที่ไม่ปลอดภัย อาจเกิดจากการแฮกชุด ช่องโหว่เว็บ หรือคนในตั้งใจปล่อย	ฐานข้อมูลดิบของระบบลงทะเบียนลูกค้าประกอบด้วยชื่อ เบอร์โทร บัตรประชาชน ถูกนำไปเผยแพร่ในเว็บบอร์ดมืด

แนวข้อสอบที่อาจออก

โจทย์: ข้อใดอธิบายความสัมพันธ์ระหว่าง Social Engineering และ Phishing ได้ถูกต้องที่สุด?

แนวคำตอบ: Social Engineering คือแนวคิดหลักเชิงจิตวิทยาที่ใช้หลอกลวงมนุษย์ ส่วน Phishing คือหนึ่งในวิธีการย่อยเชิงปฏิบัติการที่นำแนวคิดวิเคราะห์วิศวกรรมสังคมมาส่งต่อในรูปแบบข้อความหรืออีเมลอิเล็กทรอนิกส์

สรุปง่าย

Social Engineering = หลอกสมองมนุษย์ (ภาพใหญ่), **Phishing** = เมล/เว็บปลอมมาหลอก (ภาพย่อย), **Ransomware** = จับไฟล์เป็นตัวประกัน勒索者 (เรียกค่าไถ่) และ **Data Breach** = ข้อมูลความลับหลุดรั่วกระจายออกไปภายนอก

13. แนวทางการป้องกันตนเองและการใช้เทคโนโลยีดิจิทัลอย่างปลอดภัย

ในฐานะผู้ใช้งานทั่วไป (End-user) ซึ่งเป็น "ห่วงโซ่ที่อ่อนแอที่สุด" (The Weakest Link) ของระบบรักษาความปลอดภัย การปฏิบัติตามหลักการสากลพื้นฐานสามารถช่วยตัดโอกาสการตกเป็นเหยื่อไซเบอร์ได้มากกว่า 99%

เทคนิคและมาตรการป้องกันระดับบุคคล

- **การตั้งรหัสผ่านที่แข็งแกร่ง (Strong Passphrase):** หลีกเลี่ยงรหัสเดาง่าย เช่น 123456 หรือวันเกิด แนะนำให้เปลี่ยนมาใช้หลักการ **Passphrase** คือการนำคำสี่คำที่ไม่มีเกี่ยวข้องกันมาร้อยเป็นประโยคยาวๆ ใส่ตัวเลข พิมพ์ใหญ่ และอักขระพิเศษ เช่น Cyber@2026#Thai! Secure ซึ่งช่วยเพิ่มความยาว ยิงยาวคอมพิวเตอร์ยิ่งใช้เวลาถอดรหัสนานขึ้นแบบทวีคูณ (Brute-force Resistance)
- **การยืนยันตัวตนแบบหลายปัจจัย (MFA / 2FA):** การไม่พึ่งพารหัสผ่านเพียงอย่างเดียว แต่เพิ่มด่านตรวจสอบโดยคำนึงถึง 3 ปัจจัยหลัก: *Something you know* (สิ่งที่คุณรู้ เช่น รหัสผ่าน), *Something you have* (สิ่งที่คุณมี เช่น รหัส OTP ในสมาร์ตโฟน หรือกุญแจฮาร์ดแวร์), และ *Something you are* (สิ่งที่คุณเป็น เช่น ลายนิ้วมือ ใบหน้า)
- **กฎการสำรองข้อมูล 3-2-1 (3-2-1 Backup Rule):** เป็นมาตรฐานในการรักษาความพร้อมใช้งานของข้อมูล (Availability) เพื่อรับมือกับ Ransomware หรือฮาร์ดแวร์พัง:
 - เก็บข้อมูลสำคัญไว้ทั้งหมด **3 ชุด** (ข้อมูลจริง 1 ชุด และข้อมูลสำรองอีก 2 ชุด)
 - บันทึกข้อมูลลงบนสื่อจัดเก็บที่แตกต่างกันอย่างน้อย **2 ประเภท** (เช่น ในคอมพิวเตอร์เครื่องหลัก และใน External Harddrive)
 - ต้องมีข้อมูล **1 ชุด** ถูกเก็บไว้ **นอกสถานที่หรือบนระบบคลาวด์ (Offsite/Cloud Backup)** ที่ไม่ได้เชื่อมต่อกับเครือข่ายองค์กรตลอดเวลา
- **หลักการ Zero Trust (ไม่เชื่อใจใครเด็ดขาด):** ปฏิเสธการคลิกลิงก์แปลกปลอม ไม่ดาวน์โหลดซอฟต์แวร์ละเมิดลิขสิทธิ์ (โปรแกรมเถื่อนมักแฝงมัลแวร์ประเภทซ่อนเร้นมาด้วย) และหมั่นอัปเดตระบบปฏิบัติการให้เป็นเวอร์ชันล่าสุดเพื่อปิดช่องโหว่ (Zero-day vulnerabilities)

สรุปง่าย

สูตรสกัดแฮกเกอร์ระดับบุคคล: **รหัสผ่านยาวเป็นประโยค + เปิดใช้ 2FA ยืนยันตัวตนซ้ำ + สำรองข้อมูลแบบ 3-2-1 (3 ชุด / 2 สื่อ / 1 นอกสถานที่) + ปฏิบัติตามหลักการอัปเดตระบบและไม่โหลดของเถื่อน**

14. กฎหมายดิจิทัลและความมั่นคงปลอดภัยไซเบอร์ที่ควรรู้

ประเทศไทยมีกฎหมายหลัก 3 ฉบับที่ทำหน้าที่ควบคุม จัดระเบียบ และกำหนดบทลงโทษเพื่อสร้างเสถียรภาพความปลอดภัยในโลกออนไลน์ โดยมีขอบเขตและเป้าหมายที่แตกต่างกัน

3 กฎหมายสำคัญด้านไซเบอร์ของไทย

1. **พ.ร.บ. การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562:** เน้นไปที่การปกป้องโครงสร้างพื้นฐานสำคัญของประเทศ (CII) ทั้งภาครัฐและเอกชนไม่ให้ถูกโจมตีทางไซเบอร์จนทำงานไม่ได้ กฎหมายกำหนดให้หน่วยงาน CII มีหน้าที่ต้องรักษามาตรฐานความปลอดภัยและ มีหน้าที่ต้องรายงานเหตุภัยคุกคามระดับสูงหรือวิกฤตต่อ สกมช. ทันที
2. **พ.ร.บ. ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ (ฉบับปรับปรุง พ.ศ. 2560):** มุ่งเน้นการเอาผิดกับตัวบุคคล ผู้กระทำความผิด เช่น บัญญัติโทษสำหรับผู้แหกเข้าระบบคอมพิวเตอร์ผู้อื่นโดยมิชอบ (มาตรา 5-8), การแก้ไขทำลายข้อมูลคอมพิวเตอร์ (มาตรา 9-10), การส่งข้อมูลก่อวินาศกรรมหรือสแปม (มาตรา 11) และการนำเข้าข้อมูลเท็จ ข้อมูลปลอม หรือข้อมูลที่กระทบความมั่นคงเข้าสู่ระบบคอมพิวเตอร์ (มาตรา 14)
3. **พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 (PDPA):** กฎหมายเพื่อคุ้มครองสิทธิในความเป็นส่วนตัวของประชาชน บังคับใช้อย่างเข้มงวดกับองค์กรที่เก็บรวบรวม ใช้ หรือเปิดเผยข้อมูลส่วนบุคคล (Data Controller) ของลูกค้าหรือพนักงาน หากองค์กรทำข้อมูลรั่วไหล กฎหมายบังคับให้ต้องแจ้งเหตุต่อสำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล

บุคคล (สคส.) และเจ้าของข้อมูลทราบภายใน 72 ชั่วโมงนับแต่ทราบเหตุ มิฉะนั้นจะได้รับโทษปรับทางปกครองจำนวนมหาศาล

แนวข้อสอบที่อาจออก

โจทย์: บริษัทเอกชนแห่งหนึ่งโดนแฮกเกอร์โจมตีขโมยฐานข้อมูลรายชื่อ เบอร์โทรศัพท์ และเลขบัตรประชาชนของลูกค้าไปขายบนเว็บมืด ในแง่ของกฎหมาย PDPA บริษัทมีหน้าที่ต้องดำเนินการอย่างไรภายในกรอบเวลาเท่าใด?

แนวคำตอบ: บริษัทในฐานะผู้ควบคุมข้อมูลส่วนบุคคล (Data Controller) มีหน้าที่ต้องรายงานเหตุการณ์ข้อมูลรั่วไหลดังกล่าวต่อสำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล (สคส.) รวมถึงแจ้งให้ลูกค้าที่ได้รับผลกระทบทราบพร้อมแนวทางแก้ไข ภายใน 72 ชั่วโมง นับแต่ทราบเหตุ

สรุปง่าย

กฎหมายไซเบอร์ 3 ค่าย: พ.ร.บ. ไซเบอร์ฯ = ปกป้องโครงสร้างประเทศ (CII), พ.ร.บ. คอมพิวเตอร์ฯ = ลงโทษแฮกเกอร์/คนปล่อยเฟกนิวส์ และ PDPA = บังคับให้องค์กรดูแลข้อมูลเราดีๆ หากรั่วไหลต้องรับรายงานภายใน 72 ชั่วโมง

15. สรุปภาพรวมและข้อแนะนำประยุกต์สำหรับการทำข้อสอบ

ความมั่นคงปลอดภัยไซเบอร์ไม่ใช่ปัญหาด้านเทคนิคของฝ่ายไอทีเพียงอย่างเดียว แต่เป็นเรื่องของกระบวนการ นโยบาย และพฤติกรรมมนุษย์ (People, Process, and Technology) สิ่งสำคัญที่สุดในการเรียนและการสอบคือความเข้าใจความเชื่อมโยงของระบบทั้งหมดภายใต้ทฤษฎีพื้นฐาน

เสาหลักสามประการของการรักษาความปลอดภัย (CIA Triad)

ไม่ว่าระบบจะซับซ้อนเพียงใด วัตถุประสงค์สูงสุดของ Cyber Security คือการรักษาความสมดุลของ 3 สิ่งนี้:

- **C - Confidentiality (ความลับ):** ข้อมูลต้องได้รับการปกป้องไม่ให้ผู้ไม่มีสิทธิ์สามารถเข้าถึงได้ (มาตรการ: การเข้ารหัสข้อมูล, รหัสผ่าน, 2FA)
- **I - Integrity (ความถูกต้องแม่นยำ):** ข้อมูลต้องถูกต้อง ไม่ถูกแอบแก้ไข ดัดแปลง หรือปลอมแปลงระหว่างทาง (มาตรการ: Digital Signature, Hashing)
- **A - Availability (ความพร้อมใช้งาน):** ระบบและข้อมูลต้องพร้อมให้ผู้ที่มิสิทธิ์ใช้งานเข้าถึงได้ทุกเมื่อที่ต้องการ (มาตรการ: ระบบสำรอง Backup, การป้องกัน DDoS)

กลยุทธ์และเทคนิคในการทำข้อสอบให้ได้คะแนนดี

เมื่อเจอข้อสอบที่เป็นโจทย์แบบสถานการณ์สมมติ (Scenario-based) ให้ใช้หลักคิดวิเคราะห์ 3 ขั้นตอนในการตัดข้อสงสัยลง:

1. **วิเคราะห์ผู้ได้รับผลกระทบ:** ดูว่าเป็นบุคคลทั่วไป (End-user) หรือองค์กรระดับประเทศ (CII) จะช่วยคัดกรองระดับภัยคุกคามและกฎหมายที่เกี่ยวข้องได้ทันที
2. **แยกแยะเครื่องมือของคนร้าย:** แฮกเกอร์ใช้จิตวิทยาหลอก (Social Engineering), ใช้ซอฟต์แวร์เรียกไพล์ (Ransomware) หรือใช้การรุมยิง (DDoS)
3. **มองหาขั้นตอนใน Framework:** โจทย์ถามถึงขั้นเตรียมการก่อนเกิดเหตุ (Protect/Identify) หรือขั้นตอนการเข้าไปสกัดกั้นตอนเกิดเหตุแล้ว (Containment/Respond)

ข้อแนะนำทิ้งท้าย

จำไว้เสมอว่า "**ความสะดวกสบายมักสวนทางกับความปลอดภัย**" (Convenience vs Security) การเปิดยืนยันตัวตนหลายชั้นหรือการพิมพ์พาสเวิร์ดยาวๆ อาจทำให้เราเสียเวลาเพิ่มขึ้นเล็กน้อย แต่คุ้มค่าอย่างยิ่งในการปกป้องทรัพย์สินดิจิทัลและข้อมูลสำคัญของเราจากการถูกโจมตีในโลกไซเบอร์ ขอให้โชคดีในการสอบครับ!